

Anexo A

ISO 27001:2022

Control documental

Referencia documental	Versión	Fecha de la publicación	Ultima revisión



Anexo A ISO 27001:2022

Control de cambios

Versión	Fecha	Responsable del cambio	Cambios

Tabla de autorizaciones

Elaboró	Revisó	Autorizó



Anexo A ISO 27001:2022

Contenido

A.1 General.....	4
Puntos de vista de la organización.....	29

A.1 General

Este anexo proporciona una tabla para demostrar el uso de atributos como una forma de crear diferentes vistas de los controles. Los cinco ejemplos de atributos son (véase 4.2):

- a) Tipos de control (#Preventivo, #Detectivo, #Correctivo)
- b) Propiedades de seguridad de la información (#Confidencialidad, #Integridad, #Disponibilidad)
- c) Conceptos de ciberseguridad (#Identificar, #Proteger, #Detectar, #Responder, #Recuperación)
- d) Capacidades operacionales (#Gobernabilidad, #Gestión_de_activos, #Protección_de_la_información, #Seguridad_de_los_recursos_humanos, #Seguridad_física, #Seguridad_de_sistemas_y_redes, #Seguridad_de_aplicaciones, #Configuración_segura, #Identidad_y_control_de_acceso, #Amenazas_y_gestión_de_vulnerabilidades, #Continuidad, #Seguridad_en_la_relación_con_proveedores, #Cumplimiento_y_legal, #Gestión_de_eventos_de_seguridad_de_la_información, #Aseguramiento_de_seguridad_de_la_información)
- e) Dominios de seguridad (#Gobernabilidad_y_Ecosistema, #Protección, #Defensa, #Resiliencia)

La tabla A.1 contiene una matriz de todos los controles de este documento con sus valores de atributo dados.

El filtrado u ordenación de la matriz se puede lograr mediante el uso de una herramienta como una hoja de cálculo simple o una base de datos, que puede incluir más información como texto de control, orientación, orientación específica de la organización o atributos (véase A.2).

Cuadro A.1 — Matriz de controles y valores de atributos

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.1	Políticas de seguridad de la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobernabilidad	#Gobernabilidad_y_Ecosistema #Resiliencia

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.2	Funciones y responsabilidades de seguridad de la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobernabilidad	#Gobernabilidad_y_Ecosistema #Protección #Resiliencia
5.3	Separación de funciones	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gobernabilidad #Identidad_y_control_de_acceso	#Gobernabilidad_y_Ecosistema
5.4	Responsabilidades de gestión	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobernabilidad	#Gobernabilidad_y_Ecosistema
5.5	Contacto con las autoridades	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger #Responder #Recuperación	#Gobernabilidad	#Defensa #Resiliencia
5.6	Contacto con grupos de interés especial	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder #Recuperación	#Gobernabilidad	#Defensa

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.7	Inteligencia de amenazas	#Preventivo #Detectivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Detectar #Responder	#Amenazas_y_gestión_de_vulnerabilidades	#Defensa #Resiliencia
5.8	Seguridad de la información en la gestión de proyectos	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Gobernabilidad	#Gobernabilidad_y_Ecosistema #Protección
5.9	Inventario de información y otros activos asociados	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gestión_de_activos	#Gobernabilidad_y_Ecosistema #Protección
5.10	Uso aceptable de la información y otros activos asociados	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información	#Gobernabilidad_y_Ecosistema #Protección
5.11	Devolución de activos	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.12	Clasificación de la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Protección_de_la_información	#Protección #Defensa
5.13	Etiquetado de la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Protección_de_la_información	#Defensa #Protección
5.14	Transferencia de información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información	#Protección
5.15	Control de acceso	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identidad_y_control_de_acceso	#Protección
5.16	Gestión de identidades	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identidad_y_control_de_acceso	#Protección
5.17	Información de autenticación	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identidad_y_control_de_acceso	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.18	Derechos de acceso	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identidad_y_control_de_acceso	#Protección
5.19	Seguridad de la información en las relaciones con los proveedores	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_en_la_relación_con_proveedores	#Gobernabilidad_y_Ecosistema #Protección
5.20	Abordar la seguridad de la información dentro de los acuerdos con proveedores	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_en_la_relación_con_proveedores	#Gobernabilidad_y_Ecosistema #Protección
5.21	Gestión de la seguridad de la información en la cadena de suministro de las TIC	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_en_la_relación_con_proveedores	#Gobernabilidad_y_Ecosistema #Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.22	Seguimiento, revisión y gestión del cambio de los servicios de los proveedores	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_en_la_relación_con_proveedores #Aseguramiento_de_seguridad_de_la_información	#Gobernabilidad_y_Ecosistema #Protección #Defensa
5.23	Seguridad de la información para el uso de servicios en la nube	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_en_la_relación_con_proveedores	#Gobernabilidad_y_Ecosistema #Protección
5.24	Planificación y preparación de la gestión de incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperación	#Gobernabilidad #Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
5.25	Evaluación y decisión sobre eventos de seguridad de la información	#Detectivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar #Responder	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.26	Respuesta a incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperación	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
5.27	Aprender de los incidentes de seguridad de la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
5.28	Recopilación de pruebas	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar #Responder	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
5.29	Seguridad de la información durante la interrupción	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder	#Continuidad	#Protección #Resiliencia
5.30	Preparación de las TIC para la continuidad de las actividades	#Correctivo	#Disponibilidad	#Responder	#Continuidad	#Resiliencia

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.31	Requisitos legales, legales, reglamentarios y contractuales	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Cumplimiento_y_legal	#Gobernabilidad_y_Ecosistema #Protección
5.32	Derechos de propiedad intelectual	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Cumplimiento_y_legal	#Gobernabilidad_y_Ecosistema
5.33	Protección de registros	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Cumplimiento_y_legal #Gestión_de_activos #Protección_de_la_información	#Defensa
5.34	Privacidad y protección de la PII	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Protección_de_la_información #Cumplimiento_y_legal	#Protección
5.35	Revisión independiente de la seguridad de la información	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Aseguramiento_de_seguridad_de_la_información	#Gobernabilidad_y_Ecosistema

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.36	Cumplimiento de políticas, reglas y estándares de seguridad de la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Cumplimiento_y_legal #Aseguramiento_de_seguridad_de_la_información	#Gobernabilidad_y_Ecosistema

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.37	Procedimientos operativos documentados	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Recuperación	#Gestión_de_activos #Seguridad_física #Seguridad_de_sistemas_y_redes #Seguridad_de_aplicaciones #Configuración_segura #Identidad_y_control_de_acceso #Amenazas_y_gestión_de_vulnerabilidades #Continuidad #Gestión_de_eventos_de_seguridad_de_la_información	#Gobernabilidad_y_Ecosistema #Protección #Defensa
6.1	Chequeo	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobernabilidad_y_Ecosistema

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
6.2	Términos y condiciones de empleo	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobernabilidad_y_Ecosistema
6.3	Sensibilización, educación y formación en materia de seguridad de la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobernabilidad_y_Ecosistema
6.4	Proceso disciplinario	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder	#Seguridad_de_los_recursos_humanos	#Gobernabilidad_y_Ecosistema
6.5	Responsabilidades después de la terminación o cambio de empleo	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos #Gestión_de_activos	#Gobernabilidad_y_Ecosistema

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
6.6	Acuerdos de confidencialidad o no divulgación	#Preventivo	#Confidencialidad	#Proteger	#Seguridad_de_los_recursos_humanos #Protección_de_la_información #Supplier_relationships	#Gobernabilidad_y_Ecosistema
6.7	Trabajo remoto	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información #Seguridad_física #Seguridad_de_sistemas_y_redes	#Protección
6.8	Informes de eventos de seguridad de la información	#Detectivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
7.1	Perímetros de seguridad física	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
7.2	Entrada física	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Identidad_y_control_de_acceso	#Protección
7.3	Asegurar oficinas, habitaciones e instalaciones	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.4	Supervisión de la seguridad física	#Preventivo #Detectivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Detectar	#Seguridad_física	#Protección #Defensa
7.5	Protección contra amenazas físicas y ambientales	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física	#Protección
7.6	Trabajar en áreas seguras	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física	#Protección
7.7	Escritorio limpio y pantalla limpia	#Preventivo	#Confidencialidad	#Proteger	#Seguridad_física	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
7.8	Emplazamiento y protección de equipos	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.9	Seguridad de los bienes fuera de las instalaciones	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.10	Medios de almacenamiento	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.11	Servicios públicos de apoyo	#Preventivo #Detectivo	#Integridad #Disponibilidad	#Proteger #Detectar	#Seguridad_física	#Protección
7.12	Seguridad del cableado	#Preventivo	#Confidencialidad #Disponibilidad	#Proteger	#Seguridad_física	#Protección
7.13	Mantenimiento de equipos	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección #Resiliencia

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
7.14	Eliminación o reutilización segura del equipo	#Preventivo	#Confidencialidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
8.1	Dispositivos de punto final de usuario	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información	#Protección
8.2	Derechos de acceso privilegiado	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identidad_y_control_de_acceso	#Protección
8.3	Restricción de acceso a la información	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identidad_y_control_de_acceso	#Protección
8.4	Acceso al código fuente	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identidad_y_control_de_acceso #Seguridad_de_aplicaciones #Configuración_segura	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.5	Autenticación segura	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Identificación_y_control_de_acceso	#Protección
8.6	Gestión de la capacidad	#Preventivo #Detectivo	#Integridad #Disponibilidad	#Identificar #Proteger #Detectar	#Continuidad	#Gobernabilidad_y_Ecosistema #Protección
8.7	Protección contra malware	#Preventivo #Detectivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Detectar	#Seguridad_de_sistemas_y_redes #Protección_de_la_información	#Protección #Defensa
8.8	Gestión de vulnerabilidades técnicas	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Amenazas_y_gestión_de_vulnerabilidades	#Gobernabilidad_y_Ecosistema #Protección #Defensa
8.9	Gestión de la configuración	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.10	Eliminación de información	#Preventivo	#Confidencialidad	#Proteger	#Protección_de_la_información #Cumplimiento_y_legal	#Protección
8.11	Enmascaramiento de datos	#Preventivo	#Confidencialidad	#Proteger	#Protección_de_la_información	#Protección
8.12	Prevención de fugas de datos	#Preventivo #Detectivo	#Confidencialidad	#Proteger #Detectar	#Protección_de_la_información	#Protección #Defensa
8.13	Copia de seguridad de la información	#Correctivo	#Integridad #Disponibilidad	#Recuperación	#Continuidad	#Protección
8.14	Redundancia de las instalaciones de procesamiento de información	#Preventivo	#Disponibilidad	#Proteger	#Continuidad #Gestión_de_activos	#Protección #Resiliencia
8.15	Registro	#Detectivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar	#Gestión_de_eventos_de_seguridad_de_la_información	#Protección #Defensa

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.16	Actividades de seguimiento	#Detectivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar #Responder	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
8.17	Sincronización de reloj	#Detectivo	#Integridad	#Proteger #Detectar	#Gestión_de_eventos_de_seguridad_de_la_información	#Protección #Defensa
8.18	Uso de programas de utilidad privilegiados	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_sistemas_y_redes #Configuración_segura #Seguridad_de_aplicaciones	#Protección
8.19	Instalación de software en sistemas operativos	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura #Seguridad_de_aplicaciones	#Protección
8.20	Seguridad de redes	#Preventivo #Detectivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Detectar	#Seguridad_de_sistemas_y_redes	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.21	Seguridad de los servicios de red	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_sistemas_y_redes	#Protección
8.22	Segregación de redes	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_sistemas_y_redes	#Protección
8.23	Filtrado web	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_sistemas_y_redes	#Protección
8.24	Uso de la criptografía	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura	#Protección
8.25	Ciclo de vida de desarrollo seguro	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_aplicaciones #Seguridad_de_sistemas_y_redes	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.26	Requisitos de seguridad de las aplicaciones	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_aplicaciones #Seguridad_de_sistemas_y_redes	#Protección #Defensa
8.27	Arquitectura de sistemas seguros y principios de ingeniería	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_aplicaciones #Seguridad_de_sistemas_y_redes	#Protección
8.28	Codificación segura	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_aplicaciones #Seguridad_de_sistemas_y_redes	#Protección
8.29	Pruebas de seguridad en desarrollo y aceptación	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_de_aplicaciones #Aseguramiento_de_seguridad_de_la_información #Seguridad_de_sistemas_y_redes	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.30	Desarrollo externalizado	#Preventivo #Detectivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger #Detectar	#Seguridad_de_sistemas_y_redes #Seguridad_de_aplicaciones #Seguridad_en_la_relación_con_proveedores	#Gobernabilidad_y_Ecosistema #Protección
8.31	Separación de entornos de desarrollo, prueba y producción	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_aplicaciones #Seguridad_de_sistemas_y_redes	#Protección
8.32	Gestión del cambio	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_aplicaciones #Seguridad_de_sistemas_y_redes	#Protección
8.33	Información de la prueba	#Preventivo	#Confidencialidad #Integridad	#Proteger	#Protección_de_la_información	#Protección

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.34	Protección de los sistemas de información durante las pruebas de auditoría	#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_sistemas_y_redes #Protección_de_la_información	#Gobernabilidad_y_Ecosistema #Protección

La tabla A.2 muestra un ejemplo de cómo crear una vista filtrando por un valor de atributo determinado, en este caso #Correctivo.

Cuadro A.2 — Vista de los controles #Correctivo

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.5	Contacto con las autoridades	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger #Responder #Recuperación	#Gobernabilidad	#Defensa #Resiliencia
5.6	Contacto con grupos de interés especial	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder #Recuperación	#Gobernabilidad	#Defensa

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.7	Inteligencia de amenazas	#Preventivo #Detectivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Detectar #Responder	#Amenazas_y_gestión_de_vulnerabilidades	#Defensa #Resiliencia
5.24	Planificación y preparación de la gestión de incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperación	#Gobernabilidad #Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
5.26	Respuesta a incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperación	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa
5.28	Recopilación de pruebas	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar #Responder	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.29	Seguridad de la información durante la interrupción	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder	#Continuidad	#Protección #Resiliencia
5.30	Preparación de las TIC para la continuidad de las actividades	#Correctivo	#Disponibilidad	#Responder	#Continuidad	#Resiliencia
5.35	Revisión independiente de la seguridad de la información	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Aseguramiento_de_seguridad_de_la_información	#Gobernabilidad_y_Ecosistema

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.37	Procedimientos operativos documentados	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Recuperación	#Gestión_de_activos #Seguridad_física #Seguridad_de_sistemas_y_redes #Seguridad_de_aplicaciones #Configuración_segura #Identidad_y_control_de_acceso #Amenazas_y_gestión_de_vulnerabilidades #Continuidad #Gestión_de_eventos_de_seguridad_de_la_información	#Gobernabilidad_y_Ecosistema #Protección #Defensa
6.4	Proceso disciplinario	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder	#Seguridad_de_los_recursos_humanos	#Gobernabilidad_y_Ecosistema

Anexo A ISO 27001:2022

Identificador de control ISO/IEC 27002	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.7	Protección contra malware	#Preventivo #Detectivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Detectar	#Seguridad_de_sistemas_y_redes #Protección_de_la_información	#Protección #Defensa
8.13	Copia de seguridad de la información	#Correctivo	#Integridad #Disponibilidad	#Recuperación	#Continuidad	#Protección
8.16	Actividades de seguimiento	#Detectivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar #Responder	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa

Puntos de vista de la organización

Dado que los atributos se utilizan para crear diferentes vistas de controles, las organizaciones pueden descartar los ejemplos de atributos propuestos en este documento y crear sus propios atributos con diferentes valores para abordar necesidades específicas de la organización. Además, los valores asignados a cada atributo pueden diferir entre organizaciones, ya que las organizaciones pueden tener diferentes puntos de vista sobre el uso o la aplicabilidad del control o de los valores asociados al atributo (cuando los valores son específicos del contexto de la organización). El primer paso es entender por qué un atributo específico de la organización es deseable. Por ejemplo, si una organización ha construido sus planes de tratamiento de riesgos [véase ISO/IEC 27001:2013, 6.1.3 e)] basados en eventos, puede desear asociar un atributo de escenario de riesgo a cada control en este documento.

El beneficio de tal atributo es acelerar el proceso de cumplimiento del requisito ISO / IEC 27001 relacionado con el tratamiento de riesgos, que consiste en comparar los controles determinados a través del proceso de tratamiento de riesgos (denominados controles "necesarios"), con los de ISO / IEC 27001: 2013, Anexo A

(que se emiten a partir de este documento) para garantizar que no se haya pasado por alto ningún control necesario.

Una vez que se conocen el propósito y los beneficios, el siguiente paso es determinar los valores del atributo. Por ejemplo, la organización podría identificar 9 eventos:

- 1) pérdida o robo de dispositivo móvil;
- 2) pérdida o robo de las instalaciones de la organización;
- 3) fuerza mayor, vandalismo y terrorismo;
- 4) falla de software, hardware, energía, Internet y comunicaciones;
- 5) fraude;
- 6) piratería;
- 7) divulgación;
- 8) incumplimiento de la ley;
- 9) ingeniería social.

Por lo tanto, el segundo paso se puede lograr asignando identificadores a cada evento (por ejemplo, E1, E2, ..., E9).

El tercer paso consiste en copiar los identificadores de control y los nombres de control de este documento en una hoja de cálculo o base de datos y asociar los valores de atributo con cada control, recordando que cada control puede tener más de un valor de atributo.

El paso final es ordenar la hoja de cálculo o consultar la base de datos para extraer la información requerida.

Otros ejemplos de atributos organizacionales (y posibles valores) incluyen:

- a) madurez (valores de la serie ISO/IEC 33000 u otros modelos de madurez);
- b) estado de aplicación (para hacer, en curso, parcialmente implementado, plenamente implementado);
- c) prioridad (1, 2, 3, etc.);
- d) áreas organizativas involucradas (seguridad, TIC, recursos humanos, alta dirección, etc.);
- e) eventos;
- f) activos implicados;
- e) construir y ejecutar, para diferenciar los controles utilizados en las diferentes etapas del ciclo de vida del servicio;
- g) otros marcos con los que la organización trabaja o desde los que puede estar en transición.

Annex A

(informativo)

Correspondencia de ISO/IEC 27002:2022 (este documento) con ISO/IEC 27002:2013

El propósito de este anexo es proporcionar compatibilidad con versiones anteriores de ISO/IEC 27002:2013 para las organizaciones que actualmente están utilizando esa norma y ahora desean hacer la transición a esta edición.

La Tabla B.1 proporciona la correspondencia de los controles especificados en las Cláusulas 5 a 8 con los de ISO/IEC 27002:2013.

Cuadro B.1 — Correspondencia entre los controles del presente documento y los controles de la norma ISO/IEC 27002:2013

Identificador de control ISO/IEC 27002:2022	Identificador de control ISO/IEC 27002:2013	Nombre del control
5.1	05.1.1, 05.1.2	Políticas de seguridad de la información
5.2	06.1.1	Funciones y responsabilidades de seguridad de la información
5.3	06.1.2	Separación de funciones
5.4	07.2.1	Responsabilidades de gestión
5.5	06.1.3	Contacto con las autoridades
5.6	06.1.4	Contacto con grupos de interés especial
5.7	Nuevo	Inteligencia de amenazas
5.8	06.1.5, 14.1.1	Seguridad de la información en la gestión de proyectos
5.9	08.1.1, 08.1.2	Inventario de información y otros activos asociados
5.10	08.1.3, 08.2.3	Uso aceptable de la información y otros activos asociados
5.11	08.1.4	Devolución de activos
5.12	08.2.1	Clasificación de la información
5.13	08.2.2	Etiquetado de la información
5.14	13.2.1, 13.2.2, 13.2.3	Transferencia de información

Anexo A ISO 27001:2022

5.15	09.1.1, 09.1.2	Control de acceso
5.16	09.2.1	Gestión de identidades
5.17	09.2.4, 09.3.1, 09.4.3	Información de autenticación
5.18	09.2.2, 09.2.5, 09.2.6	Derechos de acceso
5.19	15.1.1	Seguridad de la información en las relaciones con los proveedores
5.20	15.1.2	Abordar la seguridad de la información dentro de los acuerdos con proveedores
5.21	15.1.3	Gestión de la seguridad de la información en la cadena de suministro de las TIC
5.22	15.2.1, 15.2.2	Seguimiento, revisión y gestión del cambio de los servicios de los proveedores
5.23	Nuevo	Seguridad de la información para el uso de servicios en la nube
5.24	16.1.1	Planificación y preparación de la gestión de incidentes de seguridad de la información
5.25	16.1.4	Evaluación y decisión sobre eventos de seguridad de la información
5.26	16.1.5	Respuesta a incidentes de seguridad de la información
5.27	16.1.6	Aprender de los incidentes de seguridad de la información
5.28	16.1.7	Recopilación de pruebas
5.29	17.1.1, 17.1.2, 17.1.3	Seguridad de la información durante la interrupción
5.30	Nuevo	Preparación de las TIC para la continuidad de las actividades
5.31	18.1.1, 18.1.5	Requisitos legales, legales, reglamentarios y contractuales
5.32	18.1.2	Derechos de propiedad intelectual
5.33	18.1.3	Protección de registros
5.34	18.1.4	Privacidad y protección de la PII
5.35	18.2.1	Revisión independiente de la seguridad de la información

Anexo A ISO 27001:2022

5.36	18.2.2, 18.2.3	Cumplimiento de políticas, reglas y estándares de seguridad de la información
5.37	12.1.1	Procedimientos operativos documentados
6.1	07.1.1	Chequeo
6.2	07.1.2	Términos y condiciones de empleo
6.3	07.2.2	Sensibilización, educación y formación en materia de seguridad de la información
6.4	07.2.3	Proceso disciplinario
6.5	07.3.1	Responsabilidades después de la terminación o cambio de empleo
6.6	13.2.4	Acuerdos de confidencialidad o no divulgación
6.7	06.2.2	Trabajo remoto
6.8	16.1.2, 16.1.3	Informes de eventos de seguridad de la información
7.1	11.1.1	Perímetros de seguridad física
7.2	11.1.2, 11.1.6	Entrada física
7.3	11.1.3	Asegurar oficinas, habitaciones e instalaciones
7.4	Nuevo	Supervisión de la seguridad física
7.5	11.1.4	Protección contra amenazas físicas y ambientales
7.6	11.1.5	Trabajar en áreas seguras
7.7	11.2.9	Escritorio limpio y pantalla limpia
7.8	11.2.1	Emplazamiento y protección de equipos
7.9	11.2.6	Seguridad de los bienes fuera de las instalaciones
7.10	08.3.1, 08.3.2, 08.3.3, 11.2.5	Medios de almacenamiento
7.11	11.2.2	Servicios públicos de apoyo
7.12	11.2.3	Seguridad del cableado
7.13	11.2.4	Mantenimiento de equipos
7.14	11.2.7	Eliminación o reutilización segura del equipo
8.1	06.2.1, 11.2.8	Dispositivos de punto final de usuario
8.2	09.2.3	Derechos de acceso privilegiado
8.3	09.4.1	Restricción de acceso a la información
8.4	09.4.5	Acceso al código fuente

Anexo A ISO 27001:2022

8.5	09.4.2	Autenticación segura
8.6	12.1.3	Gestión de la capacidad
8.7	12.2.1	Protección contra malware
8.8	12.6.1, 18.2.3	Gestión de vulnerabilidades técnicas
8.9	Nuevo	Gestión de la configuración
8.10	Nuevo	Eliminación de información
8.11	Nuevo	Enmascaramiento de datos
8.12	Nuevo	Prevención de fugas de datos
8.13	12.3.1	Copia de seguridad de la información
8.14	17.2.1	Redundancia de las instalaciones de procesamiento de información
8.15	12.4.1, 12.4.2, 12.4.3	Registro
8.16	Nuevo	Actividades de seguimiento
8.17	12.4.4	Sincronización de reloj
8.18	09.4.4	Uso de programas de utilidad privilegiados
8.19	12.5.1, 12.6.2	Instalación de software en sistemas operativos
8.20	13.1.1	Seguridad de redes
8.21	13.1.2	Seguridad de los servicios de red
8.22	13.1.3	Segregación de redes
8.23	Nuevo	Filtrado web
8.24	10.1.1, 10.1.2	Uso de la criptografía
8.25	14.2.1	Ciclo de vida de desarrollo seguro
8.26	14.1.2, 14.1.3	Requisitos de seguridad de las aplicaciones
8.27	14.2.5	Arquitectura de sistemas seguros y principios de ingeniería
8.28	Nuevo	Codificación segura
8.29	14.2.8, 14.2.9	Pruebas de seguridad en desarrollo y aceptación
8.30	14.2.7	Desarrollo externalizado
8.31	12.1.4, 14.2.6	Separación de entornos de desarrollo, prueba y producción

Anexo A ISO 27001:2022

8.32	12.1.2, 14.2.2, 14.2.3, 14.2.4	Gestión del cambio
8.33	14.3.1	Información de la prueba
8.34	12.7.1	Protección de los sistemas de información durante las pruebas de auditoría

La Tabla B.2 proporciona la correspondencia de los controles especificados en ISO/IEC 27002:2013 con los de este documento.

Cuadro B.2 — Correspondencia entre los controles de la norma ISO/IEC 27002:2013 y los controles del presente documento

Identificador de control ISO/IEC 27002:2013	Identificador de control ISO/IEC 27002:2022	Nombre de control según ISO/IEC 27002:2013
5		Políticas de seguridad de la información
5.1		Dirección de gestión para la seguridad de la información
5.1.1	5.1	Políticas de seguridad de la información
5.1.2	5.1	Revisión de las políticas de seguridad de la información
6		Organización de la seguridad de la información
6.1		Organización interna
6.1.1	5.2	Funciones y responsabilidades de seguridad de la información
6.1.2	5.3	Separación de funciones
6.1.3	5.5	Contacto con las autoridades
6.1.4	5.6	Contacto con grupos de interés especial
6.1.5	5.8	Seguridad de la información en la gestión de proyectos
6.2		Dispositivos móviles y teletrabajo
6.2.1	8.1	Directiva de dispositivos móviles
6.2.2	6.7	Teletrabajo
7		Seguridad de los recursos humanos
7.1		Antes del empleo
7.1.1	6.1	Chequeo
7.1.2	6.2	Términos y condiciones de empleo
7.2		Durante el empleo

Anexo A ISO 27001:2022

7.2.1	5.4	Responsabilidades de gestión
7.2.2	6.3	Sensibilización, educación y formación en materia de seguridad de la información
7.2.3	6.4	Proceso disciplinario
7.3		Terminación y cambio de empleo
7.3.1	6.5	Terminación o cambio de responsabilidades laborales
8		Gestión de activos
8.1		Responsabilidad por los activos
8.1.1	5.9	Inventario de activos
8.1.2	5.9	Propiedad de los activos
8.1.3	5.10	Uso aceptable de los activos
8.1.4	5.11	Devolución de activos
8.2		Clasificación de la información
8.2.1	5.12	Clasificación de la información
8.2.2	5.13	Etiquetado de la información
8.2.3	5.10	Manejo de activos
8.3		Manejo de medios
8.3.1	7.10	Gestión de soportes extraíbles
8.3.2	7.10	Eliminación de medios
8.3.3	7.10	Transferencia de medios físicos
9		Control de acceso
9.1		Requisitos empresariales de control de acceso
9.1.1	5.15	Política de control de acceso
9.1.2	5.15	Acceso a redes y servicios de red
9.2		Gestión del acceso de usuarios
9.2.1	5.16	Registro y baja de usuarios
9.2.2	5.18	Aprovisionamiento de acceso de usuario
9.2.3	8.2	Gestión de derechos de acceso privilegiado
9.2.4	5.17	Gestión de la información de autenticación secreta de los usuarios
9.2.5	5.18	Revisión de los derechos de acceso de los usuarios

Anexo A ISO 27001:2022

9.2.6	5.18	Eliminación o ajuste de los derechos de acceso
9.3		Responsabilidades del usuario
9.3.1	5.17	Uso de información secreta de autenticación
9.4		Control de acceso a sistemas y aplicaciones
9.4.1	8.3	Restricción de acceso a la información
9.4.2	8.5	Procedimientos de inicio de sesión seguros
9.4.3	5.17	Sistema de gestión de contraseñas
9.4.4	8.18	Uso de programas de utilidad privilegiados
9.4.5	8.4	Control de acceso al código fuente del programa
10		Criptografía
10.1		Controles criptográficos
10.1.1	8.24	Política sobre el uso de controles criptográficos
10.1.2	8.24	Gestión de claves
11		Seguridad física y ambiental
11.1		Áreas seguras
11.1.1	7.1	Perímetro de seguridad física
11.1.2	7.2	Controles físicos de entrada
11.1.3	7.3	Asegurar oficinas, habitaciones e instalaciones
11.1.4	7.5	Protección contra amenazas externas y ambientales
11.1.5	7.6	Trabajar en áreas seguras
11.1.6	7.2	Áreas de entrega y carga
11.2		Equipo
11.2.1	7.8	Emplazamiento y protección de equipos
11.2.2	7.11	Servicios públicos de apoyo
11.2.3	7.12	Seguridad del cableado
11.2.4	7.13	Mantenimiento de equipos
11.2.5	7.10	Eliminación de activos
11.2.6	7.9	Seguridad del equipo y los bienes fuera de las instalaciones
11.2.7	7.14	Eliminación o reutilización segura de los equipos
11.2.8	8.1	Equipo de usuario desatendido

Anexo A ISO 27001:2022

11.2.9	7.7	Política de escritorio limpio y pantalla limpia
12		Seguridad de las operaciones
12.1		Procedimientos y responsabilidades operacionales
12.1.1	5.37	Procedimientos operativos documentados
12.1.2	8.32	Gestión del cambio
12.1.3	8.6	Gestión de la capacidad
12.1.4	8.31	Separación de entornos de desarrollo, pruebas y operativos
12.2		Protección contra malware
12.2.1	8.7	Controles contra malware
12.3		Copia de seguridad
12.3.1	8.13	Copia de seguridad de la información
12.4		Registro y monitoreo
12.4.1	8.15	Registro de eventos
12.4.2	8.15	Protección de la información de registro
12.4.3	8.15	Registros de administrador y operador
12.4.4	8.17	Sincronización de reloj
12.5		Control de software operativo
12.5.1	8.19	Instalación de software en sistemas operativos
12.6		Gestión técnica de vulnerabilidades
12.6.1	8.8	Gestión de vulnerabilidades técnicas
12.6.2	8.19	Restricciones en la instalación de software
12.7		Consideraciones sobre la auditoría de los sistemas de información
12.7.1	8.34	Controles de auditoría de sistemas de información
13		Seguridad de las comunicaciones
13.1		Instalaciones de gestión de seguridad de red.
13.1.1	8.20	Controles de red
13.1.2	8.21	Seguridad de los servicios de red
13.1.3	8.22	Segregación en redes
13.2		Transferencia de información

Anexo A ISO 27001:2022

13.2.1	5.14	Políticas y procedimientos de transferencia de información
13.2.2	5.14	Acuerdos sobre transferencia de información
13.2.3	5.14	Mensajería electrónica
13.2.4	6.6	Acuerdos de confidencialidad o no divulgación
14		Adquisición, desarrollo y mantenimiento de sistemas
14.1		Requisitos de seguridad de los sistemas de información
14.1.1	5.8	Análisis y especificación de requisitos de seguridad de la información
14.1.2	8.26	Protección de los servicios de aplicaciones en redes públicas
14.1.3	8.26	Protección de las transacciones de servicios de aplicaciones
14.2		Seguridad en los procesos de desarrollo y soporte
14.2.1	8.25	Política de desarrollo seguro
14.2.2	8.32	Procedimientos de control de cambios en el sistema
14.2.3	8.32	Revisión técnica de las aplicaciones después de los cambios en la plataforma operativa
14.2.4	8.32	Restricciones en los cambios en los paquetes de software
14.2.5	8.27	Principios de ingeniería de sistemas seguros
14.2.6	8.31	Entorno de desarrollo seguro
14.2.7	8.30	Desarrollo externalizado
14.2.8	8.29	Pruebas de seguridad del sistema
14.2.9	8.29	Pruebas de aceptación del sistema
14.3		Datos de prueba
14.3.1	8.33	Protección de los datos de prueba
15		Relaciones con proveedores
15.1		Seguridad de la información en las relaciones con los proveedores
15.1.1	5.19	Política de seguridad de la información para las relaciones con los proveedores
15.1.2	5.20	Abordar la seguridad dentro de los acuerdos con proveedores

Anexo A ISO 27001:2022

15.1.3	5.21	Cadena de suministro de tecnología de la información y la comunicación
15.2		Gestión de la prestación de servicios a proveedores
15.2.1	5.22	Seguimiento y revisión de los servicios de los proveedores
15.2.2	5.22	Gestión de cambios en los servicios de los proveedores
16		Gestión de incidentes de seguridad de la información
16.1		Gestión de incidentes y mejoras de seguridad de la información
16.1.1	5.24	Responsabilidades y procedimientos
16.1.2	6.8	Notificación de eventos de seguridad de la información
16.1.3	6.8	Notificación de debilidades de seguridad de la información
16.1.4	5.25	Evaluación y decisión sobre eventos de seguridad de la información
16.1.5	5.26	Respuesta a incidentes de seguridad de la información
16.1.6	5.27	Aprender de los incidentes de seguridad de la información
16.1.7	5.28	Recopilación de pruebas
17		Aspectos de seguridad de la información de la gestión de la continuidad del negocio
17.1		Continuidad de la seguridad de la información
17.1.1	5.29	Planificación de la continuidad de la seguridad de la información
17.1.2	5.29	Implementación de la continuidad de la seguridad de la información
17.1.3	5.29	Verificar, revisar y evaluar la continuidad de la seguridad de la información
17.2		Redundancias
17.2.1	8.14	Disponibilidad de instalaciones de procesamiento de información
18		Conformidad
18.1		Cumplimiento de los requisitos legales y contractuales
18.1.1	5.31	Identificación de la legislación aplicable y los requisitos contractuales

Anexo A ISO 27001:2022

18.1.2	5.32	Derechos de propiedad intelectual
18.1.3	5.33	Protección de registros
18.1.4	5.34	Privacidad y protección de la información de identificación personal
18.1.5	5.31	Regulación de los controles criptográficos
18.2		Revisiones de seguridad de la información
18.2.1	5.35	Revisión independiente de la seguridad de la información
18.2.2	5.36	Cumplimiento de políticas y estándares de seguridad
18.2.3	5.36, 8.8	Revisión del cumplimiento técnico